Android.

L’OS open source.

US1 - Télécharger et vérifier l'APK

EN TANT que testeur
JE VEUX recevoir l’APK vulnérable déjà fourni par le PO
AFIN DE travailler sur une base commune

DoD Chaque étudiant vérifie le hash avec sha256sum app.apk et documente le résultat

US1 - Télécharger et vérifier l'APK

```
1  Get-FileHash .\app.apk -Algorithm SHA256
```

```
>  F01F08C8B6E2FE4612E81BC7E3A3BA9440DAD0D7A962F4E67640390DD721D528
```

US2 - Analyse automatisée avec MobSF

EN TANT que analyste
JE VEUX scanner l'APK avec MobSF
AFIN DE identifier rapidement métadonnées et vulnérabilité

DoD mobSF_report.pdf + résumé des vulnérabilités.

US2 - Analyse automatisée avec MobSF

```
1  docker pull opensecurity/mobile-security-framework-mobsf:latest
2  docker run -it --rm -p 8000:8000 opensecurity/mobile-security-framework-
   mobsf:latest
```

```
> [INFO] Listening at: http://0.0.0.0:8000
```

US3 - Extraction de fichiers

EN TANT que reverse-engineer
JE VEUX extraire classes.dex / Manifest.xml de l'APK
AFIN DE préparer une décompilation DoD fichiers livré avec hash SHA256.

US3 - Extraction de fichiers

```
1  Get-FileHash .\AndroidManifest.xml, .\classes.dex -Algorithm SHA256
```

```
>  80B9B101E3BF02F03EEC4F2C9C9CCF4D61403612E1435949B51CEC8B85D7A276
>  57898C5978715DA96560ED2692B4A8FA1A8E914B37988DCF369CC59951F6C429
```

US4 - Décompilation avec Apktool

EN TANT que auditeur
JE VEUX décompiler l'APK avec Apktool
AFIN DE accéder aux ressources et au manifest DoD :
Dossier app_src/ livré (zippé)

US4 - Décompilation avec Apktool

```
apktool d app.apk -o app_src
```

US5 - Analyse de strings.xml

EN TANT que analyste sécurité
JE VEUX analyser strings.xml
AFIN DE repérer secrets ou informations critiques en clair.
DoD : strings_findings.md avec extraits (⩽25 mots) et risques associés.

US6 - Analyse de code

EN TANT que ingénieur sécurité
JE VEUX décompiler le bytecode
AFIN DE trouver vulnérabilités logiques ou mauvaises pratiques DoD : code_findings.md avec explication pour chaque extrait.

US7 - Recompilation de l'APK

EN TANT que développeur
JE VEUX recompiler l’APK avec Apktool
AFIN DE vérifier que la décompilation est réversible DoD :
fichier livré + log de build

US7 - Recompilation de l'APK

```
apktool b app_src -o app_rebuilt.apk
```

US8 - Signature de l'APK

EN TANT que testeur
JE VEUX signer l’APK recompilé
AFIN DE pouvoir l’installer sur un émulateur ou terminal
DoD : rebuilt_signed.apk livré + preuve apksigner verify

US8 - Signature de l'APK

```
PS C:\Users\fesco\esiee-it\cyber\Cybers-cu\story7> & "C:\Users\fesco\AppData\Local\Android\Sdk\build-tools\36.1.0\apksigner.bat" verify app_recompiled.apk
WARNING: META-INF/android.arch.work_work-runtime.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete or move
 the entry outside of META-INF/.
WARNING: META-INF/androidx.activity_activity.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete or move the
 entry outside of META-INF/.
WARNING: META-INF/androidx.appcompat_appcompat-resources.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete
 or move the entry outside of META-INF/.
WARNING: META-INF/androidx.appcompat_appcompat.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete or move t
he entry outside of META-INF/.
WARNING: META-INF/androidx.arch.core_core-runtime.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete or mov
e the entry outside of META-INF/.
WARNING: META-INF/androidx.asynclayoutinflater_asynclayoutinflater.version not protected by signature. Unauthorized modifications to this JAR entry will not be detect
ed. Delete or move the entry outside of META-INF/.
WARNING: META-INF/androidx.cardview_cardview.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete or move the
 entry outside of META-INF/.
WARNING: META-INF/androidx.coordinatorlayout_coordinatorlayout.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected.
Delete or move the entry outside of META-INF/.
WARNING: META-INF/androidx.core_core.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete or move the entry o
utside of META-INF/.
WARNING: META-INF/androidx.cursoradapter_cursoradapter.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete o
r move the entry outside of META-INF/.
WARNING: META-INF/androidx.customview_customview.version not protected by signature. Unauthorized modifications to this JAR entry will not be detected. Delete or move
 the entry outside of META-INF/.
```

US9 - Vérification Firebase

EN TANT que pentesteur
JE VEUX tester l'accès public à une éventuelle base Firebase
AFIN DE évaluer le risque de fuite de données DoD : firebase_check.md + capture de la réponse

US9 - Vérification Firebase

```
https://firebaseremoteconfig.googleapis.com/v1/projects/717748501407/namesp
aces/firebase:fetch?key=AIzaSyBTgztvImsUfMWDa41PCrDWAj7dmyIDhUg
```

```
https://console.firebase.google.com/u/0/project/application-client-
nickel/database/application-client-nickel/data/?pli=1
```

US10 - Rapport technique

EN TANT que consultant sécurité
JE VEUX rédiger un rapport structuré
AFIN DE présenter findings, preuves et recommandations
DoD : rapport_final.pdf livré

US10 - Rapport technique

EN TANT que consultant sécurité
JE VEUX rédiger un rapport structuré
AFIN DE présenter findings, preuves et recommandations
DoD : rapport_final.pdf livré

US11 - Politique de sécurité mobile

EN TANT que responsable sécurité
JE VEUX proposer une politique mobile
AFIN DE encadrer le développement et l'usage des apps mobiles DoD : politique_mobile livré

US12 - Choix d'une solution MDM

EN TANT que architecte sécurité
JE VEUX comparer 2 solutions MDM
AFIN DE recommander la plus adaptée DoD :
mdm_recommandation livré avec tableau comparatif.

US12 - Choix d'une solution MDM

Catégories	Microsoft Intune	NinjaOne (MDM)
Architecture	Cloud Microsoft natif	SaaS cloud unifié
Gestion des identités	Intégration native et profonde avec Azure AD	Intégration via connecteurs, orientée gestion flotte
Déploiement	Autopilot (Windows), Apple Business Manager, Android Enterprise	Via portail, QR code ou intégration Apple/Google
Sécurité	Accès conditionnel, chiffrement, suppression à distance	Verrouillage, effacement à distance, réinitialisation de code rapide
Gestion applicative	Déploiement granulaire (MAM) : Word, Excel, etc.	Distribution d’apps et gestion des politiques en masse
Facilité d’usage	Complexe : nécessite des compétences	Facile : prise en main rapide
Points forts	Intégration totale avec Microsoft 365	Déploiement rapide
Inconvénients	Interface lourde pour de petites tâches	Contrôle limité sur certaines applications